Stoquify systematic review — 2026-09-05

The audit found concrete improvements and applied bounded corrections. **The configured TypeScript check and Prisma schema validation pass. 456 focused tests pass across 70 suites. Pilot and production remain unapproved.**

What improved

- Ordinary RBAC now checks live session authority instead of trusting a still-valid cookie cache after revocation.
- HTTPS dashboard routing recognizes the secure session cookie.
- Authenticated upload responses no longer permit shared caching. The separate public storage path still needs migration.
- Four baseline finance type errors were corrected: dates now use canonical string filters; export MIME/audit metadata is complete for the declared formats.
- The API inventory now flags unknown guard/module classifications and limits the public auth exception to the provider handler.
- A local database diagnostic no longer prints connection URLs or raw driver failures.
- Finance tables retain the shared toolbar/pagination styles; responsive selection and per-surface date-picker checks now pass (F17).

Most important remaining work

1. Resolve dependency security and reproducibility: installed Next.js 15.5.23 differs from CI 15.5.18; vendor security guidance identifies 15.5.24 as the patched August maintenance release. Spreadsheet import uses affected xlsx 0.18.5. No dependency upgrade was applied. See F03/F04 and P01.
2. Move tenant photos out of public delivery and persist storage configuration (F02/F15). API cache headers alone do not close the public-path exposure.
3. Bind historical COGS to posted evidence, initialize redacted operational logging, and verify concurrency/worker limits (F08–F10/F13/F14).
4. Complete exact service-guard mappings for six API endpoints. The current inventory reports 12 coverage observations, not 12 proven exploits.
5. Implement the native approval register and obtain real scoped decisions, then capture fresh X1 evidence on the stable candidate.

The dependency guidance was checked against Next.js and the SheetJS prototype-pollution and ReDoS advisories. Applicability is distinguished from a demonstrated exploit in findings.json.

Existing strengths to preserve

The inspected shared boundaries derive identity and organization server-side, restrict permissions and use safe action envelopes. Payroll transitions use persisted review evidence, actor separation, version checks and serializable retries. AP release binds to the approved destination and independent actors. Ledger invariants use Decimal amounts and per-currency balancing. Outbox claims use bounded queries and conditional leases. Public customer/supplier links bind signed tokens to live registry and content integrity. Registered agent tools

are explicitly read-only and permission/module checked. These are useful controls, not evidence of universal coverage.

X1 and approval status

Fresh X1 validation remains **blocked-awaiting-approval** with zero current artifacts. Product-budget decision, evidence authorization and authenticated matrix are missing. Preflight also lacks a run ID and approved browser storage state. The 43 listed tests are 42 route/locale/viewport cases plus aggregation; listing ran no browser.

The earlier local captures used an incorrect timing boundary and sometimes counted loading/empty placeholders. The current observer distinguishes rows, valid table-empty states and summary layouts. Historical fixture observations are not fresh database measurements. No latency improvement, zero-row correctness for the current fixture, or actual budget compliance is asserted.

The September 3 approval-register blueprint remains proposed: its models and native approval route are absent. An unsigned form, local simulator or a file hash cannot create approval authority. P07 specifies a first-time establishment process without requiring an earlier register ID. USER_ACTIONS identifies the real inputs and where to obtain them.

Scope and limits

Baseline: commit a05a41ef66cd5d98fd69ae3df18225795f912232 on codex/migration-control-plane-release-2026-08-29, with pre-existing user edits preserved. The initial inventory contains 2369 first-party code/config files and 203 Prisma models; 14 files were added to the register: one new test and 13 previously omitted localization/validation/root-test files. A generated seed-image manifest was identified and excluded. Every API handler was inspected. Selected shared and domain paths were traced; large service files and peripheral domains remain partially reviewed or unreviewed. See coverage.json and WORKFLOW_TRACES.md for the distinctions. Directory inventory is not a complete manual audit.

Type checking follows tsconfig.json, whose exclusions include tests, scripts and many legacy modules. Passing does not mean every inventoried file was type checked.

Verification used the installed local dependency graph, not CI's different npm graph. Database connections were disabled for these runs; tests primarily mock persistence. No production build, migration, reset, provider transaction, live browser capture, screen-reader session, dependency install, deployed penetration test or release activation was performed. Infrastructure, secret custody, backup restoration, provider behavior and actual human authority remain outside what these checks prove.

Verification

Check	Result	Evidence
Baseline shared security	171 tests passed	evidence/baseline-security-tests.json
New regressions before correction	Two expected failures reproduced	evidence/regression-before-fixes-tests.json
Baseline repository type check	Four finance errors	evidence/baseline-typecheck.log
Corrected security/finance	204 tests passed, 42 suites	evidence/corrected-security-finance-tests.json
Critical domains and API inventory	188 tests passed, 19 suites	evidence/critical-domain-tests.json

Check	Result	Evidence
HTTPS/local cookie routing	Three tests passed	evidence/middleware-routing-verified.json
Latest configured type check	Passed; source timing details below	evidence/concurrent-final-typecheck.json
Recheck after concurrent edits	Four failures reproduced, then corrected	evidence/concurrent-finance-recheck.json
Current finance/table/governance checks	61 tests passed in 8 suites	evidence/current-finance-verified.json
Prisma schema	Valid	evidence/prisma-schema-validate.json
X1 list	43 tests listed; no capture	evidence/x1-matrix-list.log
Current API inventory	Blocked: six endpoints need mappings	evidence/api-inventory-current.json
Current X1 validator/preflight	Blocked	evidence/x1-evidence-current.json; evidence/x1-preflight-current.json

Initial middleware test setup failures and the changed API issue-count expectation are retained alongside passing results. The type check proves the finance corrections compile; it does not prove a deployed artifact. Static diagnostic review confirms removed URL interpolation without running a credential-bearing probe.

Working-tree changes during verification

Other work changed six files after the earlier checks, including X1 observations and finance/mobile layouts. Those edits were preserved. A targeted recheck found four failures; F17 records the class and test corrections. The final finance check records before/after source fingerprints. The latest type-check snapshot and any changes during it are listed in evidence/concurrency-review.json. Class-only source edits and test corrections made after that check are separately verified by the focused run. Earlier passing results are evidence for their earlier snapshots.

No further inventoried source drift was observed after the final finance check.

Findings

F01 — RBAC accepted cookie-cached sessions after revocation (high; verified)

The shared RBAC session lookup did not bypass Better Auth's five-minute cookie cache. The new revoked-session regression failed before the correction.

A holder of an otherwise valid cached session could retain ordinary access after its backing session was revoked, until cache expiry. Fresh-auth paths had additional checks.

Correction: Force disableCookieCache:true at the shared RBAC boundary. Current user, organization and permission checks still apply.

Acceptance: Revoked authority returns no RBAC context before user lookup; active sessions still load current permissions; authority failure denies access.

Source: lib/security/rbac.ts:87, lib/auth.ts:56.

F02 — Tenant photo uploads also have a public delivery path (high; partially_verified)

The upload action writes public/uploads/<organizationId>/ and returns /uploads/...; those static URLs bypass the guarded /api/uploads handler. The API separately advertised shared caching.

Anyone with a static asset URL may access tenant photos where the host serves that public directory. No deployed exposure or access history was inspected.

Correction: Implemented private, no-store for API responses. Remaining package P02 moves assets to private versioned storage, supplies authenticated delivery and closes the legacy public and optimized-image paths.

Acceptance: API cache regression passes. Full closure additionally requires anonymous/foreign-tenant denial on both legacy and new URLs, authorized rendering/deletion, cache purge and migration hash reconciliation.

Source: actions/storage/photo-upload-actions.ts:55, actions/storage/storage-config-actions.ts:23, app/api/uploads/[...path]/route.ts:116, components/FormInputs/EnhancedImageUploadButton.tsx:187.

F03 — Installed and CI Next.js versions precede the current security patch (critical; unresolved)

Installed/pnpm Next.js is 15.5.23; npm CI selects 15.5.18. The vendor August 25 release fixes two critical issues in 15.5.24. Local and CI dependency graphs also differ for React and Better Auth.

The application can be built with a different and older security posture than the one tested locally. AVIF image optimization is an exposure candidate; the Windows issue additionally requires both routers. Exploitability and production topology are unverified.

Correction: P01: update Next.js and its lint companion to the verified patched 15.5 line, reconcile the active lockfiles in an isolated install and bind CI evidence to that exact graph.

Acceptance: Frozen installs resolve the intended patched version; dependency graph diff is reviewed; build, authentication, optimized images and key routes pass on the actual target OS.

Source: package.json:281, .github/workflows/ci.yml:57, next.config.mjs:63.

F04 — Spreadsheet import uses vulnerable SheetJS parser versions (high; unresolved)

Both installed and npm-locked xlsx are 0.18.5. Browser import handlers read selected workbooks with XLSX.read. Vendor advisories cover prototype pollution through 0.19.2 and ReDoS through 0.20.1.

A crafted workbook supplied to a user can affect the browser import workflow. Export-only call sites are not established as affected by the prototype-pollution advisory. No malicious workbook was executed.

Correction: P01: use a verified official patched distribution (at least 0.20.2 for these advisories) or a maintained replacement. Pin its integrity; bound file/row sizes and isolate parsing from the main UI thread.

Acceptance: Representative Excel files retain dates, decimals and headers; malformed and over-budget input is rejected; independently reviewed parser regression fixtures pass.

Source: components/dashboard/Tables/TableHeader.tsx:97, components/dashboard/Tables/ModalTableheader.tsx:96, package.json:309.

F05 — Finance query and export contracts prevented type checking (medium; verified)

Baseline type checking found four errors: Date[] filters supplied to string[] contracts, missing export audit watermark, and JSON omitted from the MIME mapping.

Custom-date table state and export fingerprints were inconsistent with the shared query contract. JSON export completion and audit context were incomplete.

Correction: Serialize valid dates once to ISO strings for both table and export queries, add the JSON MIME mapping and persist a tenant/request-bound watermark identifier in audit and job metadata.

Acceptance: Repository type check passes; finance workbench tests and CSV/JSON worker-lease tests pass; export audit and durable job metadata contain the same watermark.

Limit: This binds an audit identifier. It does not establish that a configured renderer embeds it into every exported file; renderer/store/download/retention readiness remains separate.

Source: components/finance/PaymentReconciliationWorkbench.tsx:387, services/accounting/finance-statement-export.service.ts:161, services/accounting/finance-statement-export.service.ts:177.

F06 — API inventory reported ready with unclassified endpoints (high; verified)

The previous inventory could report zero issues while six routes had unclassified guards and review-required module applicability. Every /api/auth/* route was broadly labeled public.

A green static report could be interpreted as coverage of routes that the scanner had not understood.

Correction: Unknown classification and module applicability now produce findings. The public Better Auth exception is limited to its exact catch-all route, and the authenticated permissions route is recognized.

Acceptance: Unknown routes, including a new auth-prefix route, fail the gate; the protected claims route remains correctly classified; all 18 inventory tests pass.

Limit: The current result is blocked with 12 observations across six routes. These are coverage gaps, not 12 demonstrated application vulnerabilities. Exact delegated-service mappings and negative tests are specified in P03.

Source: scripts/api-route-guard-inventory.js:231, scripts/api-route-guard-inventory.js:184.

F07 — HTTPS session cookie was ignored by dashboard middleware (high; verified)

The optimistic routing check recognized only better-auth.session_token, while Better Auth uses the __Secure- prefix for HTTPS.

An otherwise signed-in HTTPS user could be redirected to login before reaching server authorization.

Correction: Recognize both default cookie names. The shared server RBAC boundary still verifies the live session and permissions.

Acceptance: Both supported cookie names reach server authorization; missing and unrelated cookies redirect to localized login with the original callback.

Source: middleware.ts:103.

F08 — Shared logger defaults to a silent sink (high; unresolved)

lib/logger.ts initializes an empty sink. No first-party non-test caller of setLoggerSink was found in lib, services, app or actions; there is no root instrumentation entry point.

Operational calls through this logger can disappear, undermining incident investigation. This does not mean database audit events or every other error logger are absent.

Correction: P04: install a server startup sink using the existing canonical redaction rules, structured correlation IDs and an approved transport; add delivery health and failure behavior.

Acceptance: A synthetic safe event from a protected operation reaches the configured sink and alert path; sensitive markers do not; transport failure is visible and does not corrupt a financial transaction.

Source: lib/logger.ts:14, services/_shared/protect.ts:1.

F09 — Middleware rate limit has process-local unbounded key retention (medium; unresolved)

Each new IP creates a Map entry; entries are not removed. The counter is per process and trusts forwarded IP headers without a verified proxy contract in this review.

Long-lived instances can accumulate keys, while multiple instances do not share a limit. Spoofing depends on ingress header sanitization, which was not tested.

Correction: P04: define trusted ingress identity, use a bounded local fallback with expiry and a shared limiter for sensitive operations; measure behavior across replicas.

Acceptance: Expired keys are reclaimed; configured limits hold across two workers; spoofed client-supplied headers cannot evade the trusted ingress limit.

Source: middleware.ts:48, middleware.ts:64.

F10 — Historical analytics COGS depends on current item cost (high; unresolved)

Financial analytics computes historical COGS as sale-line quantity multiplied by the related item's current costPrice. SalesOrderLine has no immutable cost snapshot in the inspected schema.

Editing an item's cost can change reported historical margins without a new accounting event. This is an analytical read-model issue; this review does not establish ledger corruption.

Correction: P05: derive recognized COGS from the existing posted inventory valuation/ledger source for that sale and period. Show unavailable/unreconciled status when historical provenance is missing instead of inferring current cost.

Acceptance: Change an item's current cost after a posted sale; prior-period recognized COGS remains unchanged and reconciles to ledger/valuation evidence, including returns and partial deliveries.

Source: services/analytics/financial-analytics.service.ts:764, services/analytics/financial-analytics.service.ts:711, prisma/schema.prisma:4140.

F11 — Current X1 candidate has no approved authenticated capture (medium; awaiting_external_input)

Fresh validation reports blocked-awaiting-approval, zero artifacts, missing product-budget approval, evidence authorization and authenticated matrix. Preflight also lacks run ID and approved storage state. The corrected measurement helper is versioned separately from old captures.

Old zero-row counts and 7.8–63.2s capture-workflow timings cannot establish current data absence or route latency. New source changes further invalidate any assumption of candidate binding.

Correction: P06: obtain the real human decisions, prepare the authorized fixture identity, generate a new run ID automatically and collect cold/warm version-2 measurements on the final candidate.

Acceptance: All 42 route/locale/viewport captures plus aggregation bind candidate, fixture, authorization and approved budgets; errors/loading never count as valid empty data; budget pass is evaluated separately from matrix completeness.

Limit: No fresh browser capture or database fixture query was run in this audit.

Source: tests/e2e/finance-x1-route-observation.ts:11, scripts/finance-x1-evidence-preflight.ts:104, scripts/validate-finance-x1-evidence.ts:245.

F12 — Native approval register remains a blueprint (medium; proposed)

The proposed native register models and approval route are absent. The provider contract and local simulator do not establish an operating native approval authority.

Users cannot yet obtain native issued approval IDs, verification references or durable signed-record links from that proposal.

Correction: P07 implements the blueprint in stages: verified owner establishment, scoped appointments, immutable request revisions/private artifacts, authenticated decisions, validity checks, then Copy X1 fields.

Acceptance: No prior register ID is required to start establishment; real authority and verification are required to activate it. Cross-tenant, self-approval, stale revision, replay, expiry and revocation tests pass; human decisions remain distinct from POL-004 automation.

Limit: No native register, signature or approval was created by this audit.

Source: docs/approval-register/STOQUIFY_APPROVAL_REGISTER_BLUEPRINT_2026-09-03.md:41, services/governance/approval-providers/README.md:17.

F13 — Reversal numbers use count-plus-one allocation (medium; unresolved)

Reversal entry numbers are allocated by counting existing daily entries inside a default-isolation transaction. A tenant/entry-number unique constraint exists.

Concurrent reversals of different entries can select the same number and cause one transaction to fail. The unique constraint prevents this alone from proving duplicate entry numbers or double posting.

Correction: P05: reproduce with two real PostgreSQL transactions, then use a scoped sequence/counter or bounded conflict retry that preserves posting idempotency.

Acceptance: Concurrent independent reversals both complete with distinct numbers, or return an explicit retryable conflict with no partial journal, event or close-invalidation writes.

Source: services/accounting/posting.service.ts:98, services/accounting/posting.service.ts:358, prisma/schema.prisma:7711.

F14 — Timeout rejects the caller without cancelling the operation (medium; unresolved)

withAgentExecutionTimeout races a timer against an operation and clears only the timer. Its contract carries no AbortSignal or deadline to the underlying operation.

A timed-out read can continue consuming resources. Current registered tools are constrained to read-only; this is not evidence of unauthorized financial writes.

Correction: P04: pass deadlines/cancellation to adapters that support them and fence any late persistence using run/lease state. Bound uncancellable reads independently.

Acceptance: A deliberately slow adapter is cancelled or bounded, late completion cannot change a terminal run, and timeout metrics agree with observed in-flight work.

Source: services/agents/agent-execution-control.service.ts:34, services/agents/agent-runner.service.ts:327.

F15 — Storage configuration updates are not durable (medium; unresolved)

The read path builds defaults and the update path returns a constructed configuration without a durable persistence write in the inspected implementation.

A settings change can appear successful and be lost on the next read; local/online selection and limits can diverge from the UI.

Correction: Include durable tenant-scoped configuration and revision checks in P02, with server-side validation and the existing fresh-auth permission boundary.

Acceptance: Change storage mode and size limit, then read through a new request/process and observe the same authorized revision; denied users cannot change it.

Source: actions/storage/storage-config-actions.ts:95, actions/storage/storage-config-actions.ts:131.

F16 — Database diagnostic printed credential-bearing URLs (high; verified)

The local diagnostic interpolated the full database connection URL into success and failure logs; the failure also exposed the raw error message.

Running it with a credential-bearing URL could disclose credentials to terminal/log history. This audit did not run the diagnostic or establish a past leak.

Correction: Replace those messages with fixed success/failure text; do not output URL or raw driver errors.

Acceptance: Static inspection confirms both messages omit URL and driver error interpolation. Runtime diagnostic deliberately not executed.

Source: tmp-protocol-check.js:39, tmp-protocol-check.js:44.

F17 — Finance presentation and responsive test contracts were out of sync (medium; verified)

A final drift-triggered recheck reproduced four failures: financial-statement controls and cash-flow pagination lacked shared presentation markers; the selection test assumed only one responsive checkbox; a global date-picker count rejected an additional valid picker.

Shared table spacing/control rules were not applied consistently, and stale tests blocked verification of legitimate responsive changes.

Correction: Restore the existing shared toolbar/pagination classes. Scope the desktop selection action to its table, verify both desktop/mobile controls share state in both directions, and require the shared date picker separately in every named query surface.

Acceptance: All eight affected suites pass; every query surface uses the shared picker; desktop/mobile selection stays synchronized; table presentation scans detect no missing toolbar or pagination markers.

Limit: The finance dashboard was also changed by another concurrent workstream. Only the added pagination class is attributed to this audit. JSDOM does not establish viewport CSS or screen-reader behavior.

Source: app/[locale]/(dashboard)/dashboard/accounting/reports/financial-statements/financial-statement-lines-table.tsx:145, components/finance/FinanceCommandCenterDashboard.tsx:805, components/dashboard/**tests**/TransactionHistoryWorkbenchShell.test.tsx:93, components/DataTableComponents/**tests**/TableDateRangeAdoption.contract.test.ts:17.

Proceeding toward the next milestone

Continue bounded development now. Start with P01/P02 security and P03 guard coverage, while drafting P07 establishment. Refresh technical evidence only after the relevant source/dependency/fixture versions are stable. Preserve required human and runtime checks, consolidate duplicate evidence collection and resolve milestone scope explicitly. The existing production-target ancestry of Phase 2B is a policy question, not permission to bypass it.

ROADMAP.md provides ordered implementation/migration/rollback packages. USER_ACTIONS.md contains only information code inspection cannot supply. blockers-and-gates.json preserves historical B01–B12/X01–X04 context separately from current X1/API observations and catalogs 95 gate-related commands. No gate was retired and no approval fabricated.